TRUSTSEAL

System Requirements Specification, Solution Architecture, Security and User Experience Master Document

Version 2.0 | 13 November 2026 | Status: Proposed baseline for product and engineering approval

Source attribution: TrustSeal – Business Plan, v1.0 (April 2025), identifies TrustSeal as a product of EveryByte Systems, Kampala, Uganda. This document does not assert current ownership or implementation status.

Document control

Field	Details
Purpose	Consolidated product scope, implementation-ready FR/NFR catalogue, UX and engineering blueprint
Audience	Product owner, engineering, UX, QA, security, compliance, operations, commercial teams
Authority	Design proposal; requires business, legal and technical sign-off before implementation
Source baseline	TrustSeal – Business Plan (April 2025); TrustSeal UX Design Document (uploaded source)
Convention	MUST = mandatory acceptance criterion; SHOULD = recommended; MAY = optional
Priority	P0 = launch/blocker; P1 = core release; P2 = later enhancement

1. Executive summary

TrustSeal is a multi-tenant, browser-first document trust platform for producing, authorising, signing, stamping, sharing and independently verifying electronic records. Its differentiator is not the stamp graphic alone: it is the controlled authority, tamper-evident evidence and human-readable verification record associated with each transaction. The platform supports an individual workspace and organisation workspaces with independently governed assets, users, contracts, approvals, subscriptions and audit history.

The original sources envision an affordable, scalable East African product with stamps, drawn/typed/uploaded e-signatures, QR verification, contract templates, dashboards and subscriptions. This specification retains those capabilities while adding essential controls absent or underspecified in the sources: tenant isolation, stamp custody and delegation, signer consent and identity assurance, revocation semantics, signed-PDF integrity, webhook reliability, data retention, disaster recovery, accessibility, privacy, abuse prevention and traceable acceptance testing.

2. Scope and design decisions

2.1 In scope

- Individuals, business organisations and institutions; external signers without full tenant membership.
- Document ingestion, preview, preparation, editor, conversion, numbering, sharing, execution, verification and archiving.
- Personal and institutional stamps/seals; custodian-approved stamping and date stamps.
- Electronic signing, signature sequencing, optional stronger digital signatures, certificate validation, evidence files and audit trails.
- Contracts, reusable templates, obligations, expiry reminders, reporting and exports.
- Organisation administration, identity, permissions, subscriptions, tenant-scoped APIs, audit and operations.
- Responsive, accessible, deliberately flat web UI; controlled mobile signing experience.

2.2 Explicit non-goals and constraints

- Do not equate an image of a handwritten signature or a graphical stamp with a qualified cryptographic digital signature. Assurance level depends on implementation, identity proofing, cryptographic controls and jurisdiction.
- Do not claim that QR codes confer legal validity; the QR is a reference to a verification service and evidence.
- Do not permit silently changing finalised signed/stamped document bytes. Corrections require a new version and explicit linkage.
- Do not automatically grant a staff member the right to use an organisation seal merely because they can view a document.
- The source business-plan deadlines from 2025 are historical targets, not present commitments.
- AI-assisted clause or field suggestions are optional, off by default for sensitive tenants, and never finalise documents without human confirmation.

2.3 Source-derived versus recommended additions

Origin	Included capabilities / treatment
Original business plan	Custom stamps, PDF/DOCX/image upload, e-signature, QR validation, contracts, subscriptions, admin, Flask/Jinja2/PostgreSQL/PyMuPDF, Docker.
Original UX document	Sidebar modules; editor and variables; signer and stamper flows; roles; reminders; mobile; audit; extensibility.
Revised design decision	Replace original rounded/gradient button guidance with strict flat zero-radius design.
New requirements	Evidence, legal assurance tiers, stamping custody, cryptographic signatures, tenant isolation, backups, key management, WCAG, APIs, SLOs and recovery.

3. Stakeholders, actors and governance

Actor	Primary duties	Key restrictions
Platform operator	Manage infrastructure, security policy, billing configuration, incident response	No routine ability to read tenant documents; break-glass only with audit
Organisation owner/admin	Organisation setup, members, roles, templates, branding, controls	Cannot erase audit or bypass signature consent
Compliance/security officer	Inspect evidence, retention, authorisations, disputes and policy	Cannot secretly alter completed records
Stamp custodian	Manage assigned stamp/seal; approve or reject use	Cannot exceed stamp scope/validity or delegate without permission
Author/preparer	Draft, upload, place fields and initiate workflows	Cannot apply restricted seal without approval
Reviewer/approver	Comment, approve/reject assigned stage	Cannot sign as another person
Signer/external participant	Review and sign own assigned fields; download own copies	Access limited to invited envelopes/documents
Viewer/auditor	Read permitted records and evidence	No edits or approvals
Billing administrator	Seats, plans, invoices, entitlements	No implied document access
API client/service account	Scoped integration under delegated rights	No unrestricted tenant or stamp access

3.1 Permission model

Combine tenant-scoped RBAC with object-, operation- and context-level policy. Resource actions include view, create, edit, share, upload, prepare, review, approve, sign, apply_stamp, issue_seal, verify, revoke, export, delete, administer, audit_read, billing_manage, key_manage. Enforcement is server-side, deny-by-default and tested for cross-tenant and inherited-access bypasses. An invitation is a limited access capability, not a member role.

4. End-to-end business workflows

4.1 Document lifecycle and status

```
DRAFT -> PREPARED -> IN_REVIEW -> APPROVED -> SENT -> IN_PROGRESS -> COMPLETED -> ARCHIVED
           |          |           |            |
           v          v           v            v
       REJECTED    REJECTED    DECLINED    EXPIRED / CANCELLED
```

REVOKED is a status on a verification credential/stamp authority, not a silent rewrite of completed evidence.

A document version is immutable after issuance for execution. Each workflow references an exact version and content digest. A rejected workflow returns to a new editable draft version, not the previously issued

document. Completion is terminal for the execution envelope; corrections are follow-on envelopes linked by supersedes/superseded_by.

4.2 Signer and stamping journey

- Prepare: upload/draft, choose workspace, classify sensitivity, select parties, place accessible fields, define routing and deadlines, run validation and preview.
- Invite: deliver secure invitation with short-lived token; authenticate/verify identity at required assurance level; display recipient, document, signing intent and consent.
- Execute: signer reviews full record, signs assigned fields, explicitly confirms completion; preserve event and evidence; apply permitted cryptographic finalisation.
- Stamp: authorised user requests restricted stamp, custodian/policy approves, server binds exact stamp revision, stamp appearance, actor, document digest and timestamp.
- Verify: visitor opens QR/reference, sees limited public trust summary, verifies document hash or downloads authorised evidence, and is informed of expired/revoked credentials.
- Archive: record disposition rules, access and legal hold; export signed copy, certificate/evidence, audit and machine-readable verification record.

4.3 Approval, delegation and exception handling

Sequential and parallel steps, quorum and conditional routing are supported. Expiry, signer refusal, identity-check failure, unavailable custodian, rejected approval or document alteration must halt progression with a clear remedial action. Delegation is time-bound, approved, scope-limited and attributable to the delegate. A cancelled envelope preserves evidential history.

5. Functional requirements (FR)

Each requirement includes a verifiable outcome. IDs are stable within this version and must be referenced in development tickets and automated tests. Priorities are proposals for planning.

5.1 Identity, authentication and access

ID	Pri.	Requirement	Acceptance evidence
FR-ID-001	P0	The platform MUST support verified email registration, login, logout and secure password reset	Activation and reset links are one-time, expiring and audited.
FR-ID-002	P0	The platform MUST require MFA for privileged roles and allow TOTP or passkeys	Privileged login without configured factor is blocked; recovery is audited.
FR-ID-003	P0	The platform MUST enforce deny-by-default tenant-scoped permissions on every API action	Cross-tenant and privilege-escalation tests fail closed.
FR-ID-004	P0	The platform MUST terminate or rotate sessions on logout, password reset and privilege change	Reused revoked session is rejected.
FR-ID-005	P1	The platform MUST support single sign-on with OIDC/SAML for eligible tenants	JIT provisioning and mapped roles are tested.

ID	Pri.	Requirement	Acceptance evidence
FR-ID-006	P1	The platform MUST support invited external signers with least-privilege, time-limited access	Link does not expose other records; expiration enforced.
FR-ID-007	P1	The platform MUST support device and session history with administrator revocation	Revoked device loses access promptly.
FR-ID-008	P1	The platform MUST support configurable identity assurance policies per workflow	Higher-assurance workflow cannot proceed with lower evidence.
FR-ID-009	P2	The platform SHOULD support SCIM provisioning and offboarding	User removal disables access without destroying historic attribution.

5.2 Organisations, teams and authorisation

ID	Pri.	Requirement	Acceptance evidence
FR-ORG-001	P0	The platform MUST isolate documents, stamps, members and billing per organisation	Tests prove no cross-tenant reads or writes.
FR-ORG-002	P0	The platform MUST maintain immutable identifiers for organisations, users, memberships and roles	Activity retains actor even after membership removal.
FR-ORG-003	P0	Organisation admins MUST invite, suspend and deactivate members	Rights are checked at both UI and API.
FR-ORG-004	P1	The platform MUST support role templates plus granular overrides	Effective permissions are inspectable and testable.
FR-ORG-005	P1	The platform MUST support teams, departmental folders and ownership assignment	Members see only permitted folders/resources.
FR-ORG-006	P1	The platform MUST allow approval policies based on stamp, amount, department or document type	Policy routing matches deterministic test cases.
FR-ORG-007	P1	Delegation MUST be explicit, expiring and recorded with reason	Delegated stamp use shows actual actor and authority chain.
FR-ORG-008	P1	The platform MUST log policy/role changes and notify relevant owners	Audit includes old/new values and actor.
FR-ORG-009	P2	The platform SHOULD support organisation hierarchies and group policy inheritance	Conflicting rules resolve using deny-overrides.

5.3 Document storage and lifecycle

ID	Pri.	Requirement	Acceptance evidence
FR-DOC-001	P0	Users MUST upload PDF and supported DOCX/image formats subject to size and content validation	Unsupported and malware-positive files rejected.
FR-DOC-002	P0	The system MUST generate a stable document identifier, revision and checksum at ingestion	Hash matches stored original bytes.
FR-DOC-003	P0	Every issued execution MUST bind exactly one immutable document revision	Changing a draft creates new revision.
FR-DOC-004	P0	The system MUST provide server-rendered safe preview with page navigation	Active script and embedded content never execute in preview.
FR-DOC-005	P1	Users MUST classify, tag, search, sort and filter documents	Tenant search only returns authorised items.
FR-DOC-006	P1	Users MUST create, rename, duplicate and move drafts within permissions	Permission and change history enforced.
FR-DOC-007	P1	Users MUST download original and authorised final PDF with evidence package	Export includes manifest/checksums.
FR-DOC-008	P1	The system MUST support bulk upload and recoverable upload failures	Partial batches report per-file outcomes.
FR-DOC-009	P1	Records MUST support retention dates, archive and controlled deletion	Holds prevent deletion and audit remains intact.
FR-DOC-010	P1	The system MUST detect duplicates and show content revisions	Duplicate does not overwrite an existing record.
FR-DOC-011	P2	The system SHOULD support OCR-backed search with confidence/display controls	Low-confidence extracted text is marked.
FR-DOC-012	P2	The system MAY support encrypted offline draft editing without offline completion of authoritative signatures	Conflict and trust caveats surfaced.

5.4 Authoring, templates and field preparation

ID	Pri.	Requirement	Acceptance evidence
FR-EDIT-001	P1	Users MUST create documents from rich-text templates and named variables	Preview renders supplied values safely.

ID	Pri.	Requirement	Acceptance evidence
FR-EDIT-002	P1	The editor MUST support headings, tables, clauses and basic numbering	Saved draft reopens without data loss.
FR-EDIT-003	P1	The editor MUST autosave drafts and restore recent edits	Recovery scenario passes after interrupted network.
FR-EDIT-004	P1	Preparers MUST place signature, initials, date, text, checkbox and stamp fields on exact pages	Final PDF coordinates match editor preview.
FR-EDIT-005	P1	Each field MUST have an assignee, validation rules and required/optional designation	Submission blocks missing mandatory fields.
FR-EDIT-006	P1	Templates MUST have revision history, owners and publish/archive states	Existing issued envelopes retain template revision.
FR-EDIT-007	P1	Variables MUST be escaped, typed and checked for missing values	Injection and unbound variable tests pass.
FR-EDIT-008	P1	Users MUST preview generated content and generated PDFs before sending	No envelope sent before explicit confirmation.
FR-EDIT-009	P2	Approved clause libraries SHOULD restrict editing of controlled clauses	Controlled variants record approver and revision.
FR-EDIT-010	P2	Optional AI clause/field suggestions MUST require opt-in and manual acceptance	No confidential content sent to third parties without policy consent.

5.5 Electronic signatures and evidence

ID	Pri.	Requirement	Acceptance evidence
FR-SIGN-001	P0	Signers MUST receive secure, recipient-specific signing invitations	Token is bound to recipient and envelope with expiry.
FR-SIGN-002	P0	Signers MUST review the document and explicitly consent to electronic execution	Consent version, timestamp and intent captured.
FR-SIGN-003	P0	The system MUST support drawn, typed and uploaded signature appearances where policy allows	Appearance is linked to the attesting actor and evidence.
FR-SIGN-004	P0	Each signature MUST be bound to document hash, actor, envelope and event time	Modification breaks verification or changes status.
FR-SIGN-005	P0	The system MUST generate tamper-evident completion evidence and a final PDF	Independent hash comparison and audit verification pass.
FR-SIGN-006	P1	Signers MUST complete	Attempted field crossover

ID	Pri.	Requirement	Acceptance evidence
		assigned required fields and cannot alter others' fields	rejected.
FR-SIGN-007	P1	Workflows MUST support sequential and parallel signers, CC recipients and optional witnesses	Order and pending state deterministic.
FR-SIGN-008	P1	The system MUST support reminders, expiry, resend, decline and cancellation with reasons	Each action has event and notification.
FR-SIGN-009	P1	The system MUST support signer authentication challenges selected by sender policy	Audit captures challenge type and outcome, not secrets.
FR-SIGN-010	P1	Where stronger assurance is selected, the platform MUST support certificate-backed PDF signatures via protected keys	PAdES profile and trust-chain validation tested.
FR-SIGN-011	P1	Signing evidence MUST include invitation, consent, authentication events, timestamps, IP/device metadata subject to privacy policy	Exportable evidence bundle is complete and access controlled.
FR-SIGN-012	P2	The platform SHOULD support multiple signature certificates and long-term validation material	Revocation/trust snapshots support offline revalidation.

5.6 Stamps, company seals and custody

ID	Pri.	Requirement	Acceptance evidence
FR-STAMP-001	P0	The system MUST maintain personal, team and organisation stamp assets with immutable asset IDs	Asset ownership and scope inspectable.
FR-STAMP-002	P0	Stamp creation MUST allow text, logo, circles/rectangles, border weights, ink colours and configurable dates	Output matches versioned preview at normal print scale.
FR-STAMP-003	P0	Restricted company seals MUST require explicit custodian or policy authorisation before use	Unauthorised stamp application rejected server-side.
FR-STAMP-004	P0	Every applied stamp MUST bind asset revision, actor, authority, page coordinates, document hash and UTC timestamp	Evidence record independently resolves these fields.
FR-STAMP-005	P0	The system MUST distinguish visual stamps from certified or legally authorised seals	UI and verification page state actual assurance level.
FR-STAMP-006	P1	Stamp owners MUST configure	Out-of-scope use cannot

ID	Pri.	Requirement	Acceptance evidence
		validity dates, intended use, allowed roles, approval policy and permitted organisations	proceed.
FR-STAMP-007	P1	Stamp requests MUST support approve, reject, revoke pending request and escalation	Approval chain and decision times recorded.
FR-STAMP-008	P1	Date stamps MUST support configurable date format and red date ink independent of other stamp ink	Date output is reproduced from server time and recorded timezone.
FR-STAMP-009	P1	Users MUST place, scale, rotate, repeat on selected pages and preview stamp impressions	Coordinates are consistent after PDF rendering.
FR-STAMP-010	P1	The system MUST preserve historical impressions when a stamp asset is retired or revoked	Public verifier distinguishes prior valid use and subsequent revocation.
FR-STAMP-011	P1	The system MUST support dual-control for high-assurance seals	Requester cannot self-approve when separation policy applies.
FR-STAMP-012	P1	Stamp assets MUST use protected storage and access logging	Gallery and file endpoints respect custodian permissions.
FR-STAMP-013	P2	Users SHOULD be able to import an authorised transparent stamp image with cropping and quality checks	Import provenance and asset revision retained.
FR-STAMP-014	P2	Administrators SHOULD support official stamp templates per institution with locked layout elements	Template rules enforce protected components.

5.7 QR verification, integrity and trust

ID	Pri.	Requirement	Acceptance evidence
FR-VRF-001	P0	Every issued trust record MUST have an unguessable verification reference and QR URL	Random guessing does not expose sensitive data.
FR-VRF-002	P0	Public verification MUST display authenticity status without disclosing private document content	Anonymous viewer sees metadata-minimal response.
FR-VRF-003	P0	Uploaded document verification MUST calculate digest and compare with issued canonical record	Altered bytes produce mismatch state.
FR-VRF-004	P0	The verifier MUST differentiate valid, unverifiable, expired, revoked, replaced and unknown	UI tests cover every state.

ID	Pri.	Requirement	Acceptance evidence
		records	
FR-VRF-005	P1	Verification MUST display issuer, issued time, record status and stamp/signature assurance claims	Claims grounded in stored evidence, not graphic alone.
FR-VRF-006	P1	Organisations MUST configure allowed public fields and redaction of identities/titles	Privacy preview matches public page.
FR-VRF-007	P1	Verification events MUST be rate limited and logged without unnecessary personal data	Brute-force attempts throttled.
FR-VRF-008	P1	An authorised verifier MUST download or inspect evidence packages with access logging	Access policy applied to all attachments.
FR-VRF-009	P1	Certificate-backed PDFs MUST be checked for cryptographic validity and revocation status	Trust result reports chain/timestamp status.
FR-VRF-010	P2	The platform SHOULD expose signed verification attestations for system-to-system consumers	Detached attestation verifies via published keys.

5.8 Contract lifecycle and obligations

ID	Pri.	Requirement	Acceptance evidence
FR-CTR-001	P1	Users MUST initiate contracts from uploaded files or approved templates	Contract record links versioned source.
FR-CTR-002	P1	Contracts MUST have parties, owners, type, effective date, duration and status	Required metadata validated.
FR-CTR-003	P1	Contracts MUST support draft, review, approval, execution, active, expired and terminated states	Transition rules enforced by role.
FR-CTR-004	P1	Contracts MUST support review comments, tracked versions and decision reasons	History displays actor and timestamp.
FR-CTR-005	P1	Contracts MUST support milestones, obligations and renewals with assigned owners	Reminders fire at configured dates.
FR-CTR-006	P1	Contract search MUST filter by party, owner, date, value, stage and renewal	Result scopes align with permissions.
FR-CTR-007	P1	The system MUST identify superseded and amended contracts	Linked chain retained permanently subject to retention.
FR-CTR-008	P2	Contracts SHOULD support structured clause extraction and	Extracted items retain source-page evidence.

ID	Pri.	Requirement	Acceptance evidence
		risk tagging	
FR-CTR-009	P2	Contracts SHOULD support approval thresholds and delegation of authority	Threshold test routes to correct authority.
FR-CTR-010	P2	Contracts MAY support approved counterparty negotiation portal	Changes are versioned and approved before execution.

5.9 Sharing, communication and collaboration

ID	Pri.	Requirement	Acceptance evidence
FR-SHR-001	P0	Shared document access MUST be restricted by authenticated identity or expiring scoped token	Reused/revoked token fails.
FR-SHR-002	P1	Users MUST invite reviewers, signers, viewers and stampers by role-specific action	Invitation grants no excess permissions.
FR-SHR-003	P1	Internal comments and mentions MUST be visible only to authorised participants	External signers cannot read internal comments.
FR-SHR-004	P1	Notifications MUST support email and configurable SMS provider with queued retries	Failed send retried and surfaced.
FR-SHR-005	P1	Users MUST manage reminder schedules without spamming participants	Frequency caps enforced.
FR-SHR-006	P1	Downloads and external link shares MUST optionally be disabled by policy	Access control works across preview and APIs.
FR-SHR-007	P1	Users MUST view delivery, open, viewed, approved and signed activity	Event timeline reflects verified delivery state.
FR-SHR-008	P2	The platform SHOULD support read receipts and branded notification templates	All messages provide explicit source identity.

5.10 Subscriptions, billing and entitlements

ID	Pri.	Requirement	Acceptance evidence
FR-SUB-001	P0	The system MUST model Free, Pro, Business and Enterprise plans without hardcoding price	Entitlements can be changed by authorised operator.
FR-SUB-002	P0	All paid feature gates MUST be enforced server-side	Direct API request without entitlement denied.
FR-SUB-003	P1	Organisations MUST view current plan, seat use, storage,	Usage agrees with metering ledger.

ID	Pri.	Requirement	Acceptance evidence
		document allowance and billing period	
FR-SUB-004	P1	Billing MUST support trial, upgrade, downgrade, grace, suspension and cancellation policies	State transitions tested without data deletion.
FR-SUB-005	P1	The system MUST integrate at least one compliant payment provider by hosted checkout or tokenised collection	No raw payment-card data stored by TrustSeal.
FR-SUB-006	P1	Billing admins MUST access invoices, receipts, tax profile and payment history	Exports reconcile with billing ledger.
FR-SUB-007	P1	Usage events MUST be deduplicated and attributable to tenant/plan	Retry never creates double charge.
FR-SUB-008	P1	Plan downgrade MUST preserve historical trust records and offer safe read-only access	Completed evidence remains retrievable subject to policy.
FR-SUB-009	P2	Enterprise plans SHOULD support annual contracts, custom limits and purchase orders	Manual invoicing and entitlements auditable.

5.11 Administration, monitoring and audit

ID	Pri.	Requirement	Acceptance evidence
FR-ADM-001	P0	The system MUST write append-only security and trust events for privileged, stamping and signing actions	Events carry timestamp, actor, tenant, object and correlation ID.
FR-ADM-002	P0	Tenant administrators MUST view scoped audit trail; platform operators MUST not access tenant content without break-glass	Audit access tested and logged.
FR-ADM-003	P1	Admins MUST configure organisation branding, notification defaults, domains and retention	Saved settings versioned.
FR-ADM-004	P1	Compliance officers MUST export audit and evidence reports	Exports are access controlled and checksum-manifested.
FR-ADM-005	P1	Platform administrators MUST manage service health, workers, failed jobs and integration status	Failed jobs distinguish retryable/permanent.
FR-ADM-006	P1	Operator tools MUST support account lock, legal hold, abuse investigation and safe recovery	Sensitive operations require reason and elevated checks.

ID	Pri.	Requirement	Acceptance evidence
FR-ADM-007	P1	The system MUST monitor security alerts including repeated failures and abnormal stamp use	Alert event produced on configured threshold.
FR-ADM-008	P2	The platform SHOULD provide usage analytics without exposing document content to unauthorised operators	Metrics aggregated per tenant.

5.12 APIs, integrations and extensibility

ID	Pri.	Requirement	Acceptance evidence
FR-API-001	P1	The platform MUST expose versioned REST APIs for documents, envelopes, stamps, verification, organisations and audit	OpenAPI schema and contract tests pass.
FR-API-002	P1	API credentials MUST use tenant-scoped service accounts with granular scopes, rotation and expiry	Revoked credentials rejected.
FR-API-003	P1	Webhooks MUST be signed, retryable, idempotent and replay-protected	Consumer verifies signature and duplicate delivery.
FR-API-004	P1	Background tasks MUST expose observable states and dead-letter recovery	Failures can be retried safely.
FR-API-005	P1	External storage and e-mail/SMS providers MUST be configured behind replaceable adapters	Contract tests pass across adapters.
FR-API-006	P2	The platform SHOULD integrate with common document suites via import/export connectors	Connector respects source ACL and tenant boundary.
FR-API-007	P2	The platform SHOULD support government or institutional trust registry integration where legally/technically authorised	Each integration uses scoped credentials and documented assurance mapping.
FR-API-008	P2	The platform MAY offer webhooks, SDKs and tenant-sandbox API keys	Sandbox is isolated from production data.

5.13 Privacy, security and evidence operations

ID	Pri.	Requirement	Acceptance evidence
FR-SEC-001	P0	Files MUST be scanned, validated and rendered in an isolated, resource-limited	Malicious document test cannot reach application services.

ID	Pri.	Requirement	Acceptance evidence
		conversion environment	
FR-SEC-002	P0	The platform MUST encrypt sensitive data in transit and at rest with managed keys	Security configuration audit confirms enforcement.
FR-SEC-003	P0	The platform MUST keep immutable audit evidence and establish tamper-detection	Deleting or changing an event creates detectable gap.
FR-SEC-004	P0	The system MUST support tenant and user data subject access and erasure workflows subject to legal retention	Request history and exceptions documented.
FR-SEC-005	P1	The system MUST define retention classes, legal holds and secure destruction jobs	Hold overrides purge and destruction is auditable.
FR-SEC-006	P1	Secrets and signing keys MUST be stored outside source code in vault/KMS/HSM as assurance requires	Key rotation does not break evidence validation.
FR-SEC-007	P1	High-risk actions MUST require step-up authentication and dual control where policy requires	Session-only action denied when step-up expired.
FR-SEC-008	P1	The system MUST prevent sensitive data leakage in logs, URLs, notifications and public QR result	Log scanning and privacy tests pass.
FR-SEC-009	P1	Operator access to content MUST use time-limited break-glass with reason, approval and complete logging	Incident drill reconstructs access.
FR-SEC-010	P2	Organisations SHOULD support data residency and export controls in enterprise deployment	Hosting location displayed and enforced per tenant.

5.14 Experience, accessibility and usability

ID	Pri.	Requirement	Acceptance evidence
FR-UX-001	P0	The entire UI MUST use a flat visual system with zero corner radius and zero gradients	Visual regression detects no radius or gradient tokens.
FR-UX-002	P0	Navigation MUST expose only authorised modules and actions, while enforcing all controls server-side	Persona route/access tests pass.
FR-UX-003	P0	Every destructive or trust-critical operation MUST have clear confirmation, affected object and status	User cannot unintentionally finalise or delete.
FR-UX-004	P0	Every form MUST provide	Keyboard and screen-reader

ID	Pri.	Requirement	Acceptance evidence
		persistent labels, instructions and field-level validation	review passes.
FR-UX-005	P1	List views MUST support search, filters, sorting, pagination and saved columns where useful	Dense 1280px layout avoids clipping.
FR-UX-006	P1	Document preparation MUST have a single primary action per stage and explicit progress	User tests complete core flow without training.
FR-UX-007	P1	Mobile signing MUST remain usable at 320 CSS pixels without horizontal page scrolling, except document canvas	Responsive tests pass.
FR-UX-008	P1	All dialogs, dropdowns and tools MUST be operable by keyboard with visible focus	Accessibility automation and manual tests pass.
FR-UX-009	P1	The platform MUST make verification status readable in text, not only colour	Monochrome and screen-reader checks pass.
FR-UX-010	P2	The platform SHOULD offer multilingual UI via localisation framework	UI strings extracted and language switch persisted.

6. Non-functional requirements (NFR)

Targets below are proposed engineering service objectives, not claims about current deployment. Confirm commercial SLOs after load and failure testing.

6.1 Security and privacy

ID	Pri.	Requirement	Acceptance evidence
NFR-SEC-001	P0	All endpoints MUST use TLS 1.2+ with modern cipher configuration	Automated TLS scan passes agreed policy.
NFR-SEC-002	P0	Sensitive storage MUST use encryption with documented key custody	Encryption/KMS test and restore procedure verified.
NFR-SEC-003	P0	Access checks MUST run on every server-side read, mutation and download	IDOR and tenant isolation penetration suite passes.
NFR-SEC-004	P0	Critical vulnerabilities MUST block release; high findings need tracked risk decision	CI policy gate and exception registry present.
NFR-SEC-005	P0	Trust-critical events MUST be tamper-evident and timestamped in UTC	Evidence verification detects alteration.

ID	Pri.	Requirement	Acceptance evidence
NFR-SEC-006	P1	Security logs SHOULD be retained 365 days or policy-defined period with restricted access	Retention job and archive test pass.
NFR-SEC-007	P1	Passwords MUST be hashed using strong memory-hard KDF and unique salts	Security code audit verifies algorithm.
NFR-SEC-008	P1	Public verification and invite flows MUST rate-limit brute force and enumeration	Abuse tests demonstrate throttling.
NFR-SEC-009	P1	Backups and exports MUST have encryption and access controls	Unauthorized download fails.
NFR-SEC-010	P1	Personal data processing MUST be mapped to a published privacy inventory and lawful basis	Approved data map exists.

6.2 Performance, scalability and capacity

ID	Pri.	Requirement	Acceptance evidence
NFR-PER-001	P0	p95 authenticated page navigation SHOULD complete within 2.5 s under reference load	Browser synthetic test across standard routes.
NFR-PER-002	P0	p95 ordinary API reads SHOULD complete within 500 ms excluding file rendering	Load-test dashboard supports result.
NFR-PER-003	P1	p95 search queries SHOULD complete within 2 s over 100k tenant records	Query benchmark passes with representative indexes.
NFR-PER-004	P1	First page preview SHOULD render within 4 s for a typical 10 MB PDF	Representative device/network test passes.
NFR-PER-005	P1	System SHOULD support at least 200 concurrent active users in pilot baseline	Sustained test has no SLO breach.
NFR-PER-006	P1	Asynchronous processing MUST remain idempotent under retries and restarts	Fault injection creates exactly one effective result.
NFR-PER-007	P1	Storage SHOULD scale independently from application compute	Horizontal scaling exercise without data loss.
NFR-PER-008	P2	Performance SLOs SHOULD be configurable by tier and monitored by geography	Tier report published each release.

6.3 Availability, resilience and disaster recovery

ID	Pri.	Requirement	Acceptance evidence
NFR-REL-001	P0	Production SHOULD meet 99.9% monthly service availability after pilot stabilisation	Synthetic external availability monitoring.
NFR-REL-002	P0	Signed and stamped records MUST survive worker crashes and client retries without corruption	Recovery integration test passes.
NFR-REL-003	P0	A failed request MUST never cause duplicate signature/stamp issuance	Replayed request has same idempotent outcome.
NFR-REL-004	P1	Target recovery point objective SHOULD be 15 minutes for primary metadata	Restore drill demonstrates RPO.
NFR-REL-005	P1	Target recovery time objective SHOULD be 4 hours for regional infrastructure failure	DR simulation demonstrates RTO.
NFR-REL-006	P1	Backups MUST be automatic, encrypted, periodically test-restored and monitored	Monthly sample restore evidence recorded.
NFR-REL-007	P1	Dead-letter jobs and replay controls MUST exist for delivery failures	Operator recovers representative failed task.
NFR-REL-008	P1	External notification or payment outages MUST not lose core document state	Fault injection keeps workflow consistent.

6.4 Accessibility, maintainability and interoperability

ID	Pri.	Requirement	Acceptance evidence
NFR-USE-001	P0	UI MUST target WCAG 2.2 AA and accommodate keyboard-only use	Automated and manual audit with tracked exceptions.
NFR-USE-002	P0	UI MUST use zero-radius controls, no gradients, no decorative pill badges or chip highlights	Theme token and screenshot checks pass.
NFR-USE-003	P1	Standard flows SHOULD require no more than 5 user-directed stages to send a prepared document	Moderated usability test on representative tasks.
NFR-USE-004	P1	Supported desktop browsers SHOULD include current Chromium, Firefox and Safari releases	Cross-browser automated E2E passes.
NFR-USE-005	P1	API SHOULD publish OpenAPI 3.x definitions and deprecation	Schema validation and compatibility tests pass.

ID	Pri.	Requirement	Acceptance evidence
		policy	
NFR-USE-006	P1	Business logic MUST be covered by automated tests and protected by migration checks	Coverage trends and regression suite reviewed.
NFR-USE-007	P1	Key events MUST use structured correlation IDs and redacted observability payloads	Trace from request through worker established.
NFR-USE-008	P1	Database schema MUST support reversible migrations where practicable and mandatory backups for destructive changes	Staging migration and recovery test pass.
NFR-USE-009	P2	The app SHOULD support internationalisation and selectable timezones while storing UTC	Locale/date formatting tests pass.

6.5 Legal defensibility and operational assurance

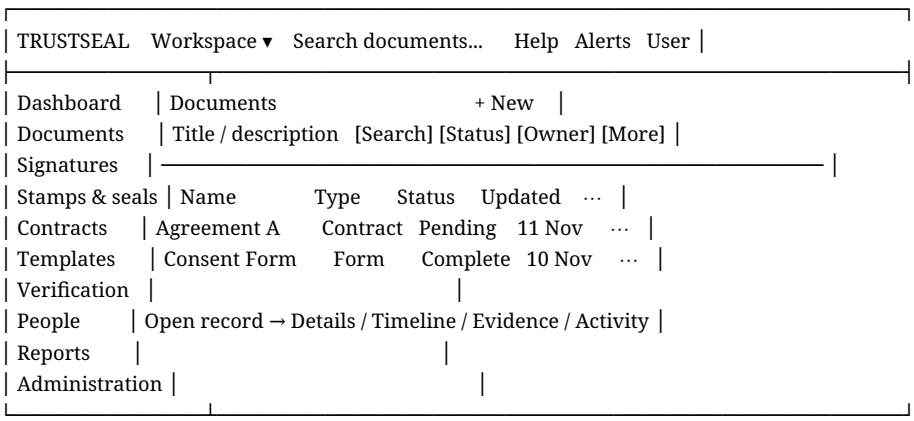
ID	Pri.	Requirement	Acceptance evidence
NFR-LEGAL-001	P0	Every execution MUST retain exact document digest, participant consent and attributable activity evidence	Dispute replay reconstructs complete sequence.
NFR-LEGAL-002	P0	System MUST label electronic signature, advanced/certificate-backed signature and graphical stamp distinctly	User and verification pages do not conflate categories.
NFR-LEGAL-003	P0	Platform MUST publish policies explaining trust limitations, retention and verification states	Legal review signs off wording before launch.
NFR-LEGAL-004	P1	Trusted timestamp and certificate service integrations SHOULD be supported for high-assurance workflows	Evidence validates trust source and timestamp.
NFR-LEGAL-005	P1	The system MUST preserve complete evidence chain when assets are revoked or signer account deleted	Historical record verifiable without active user.
NFR-LEGAL-006	P1	Electronic evidence export MUST be machine-readable and independently checkable	Independent verifier confirms hashes/signatures.
NFR-LEGAL-007	P1	Compliance mapping MUST be validated for each launch jurisdiction by qualified counsel	Recorded sign-off before local high-assurance claims.
NFR-LEGAL-008	P2	Accessibility and records retention SHALL follow approved client-specific policies	Enterprise compliance report available.

7. Flat user interface and UX standard

7.1 Non-negotiable UI tokens

Element	Mandatory specification
Surface	White #FFFFFF main; optional neutral #F5F6F7 page; restrained blue #164C83 only for primary actions/links.
Borders	1px #D6DADE separators; no heavy card surrounds; strong focus outline 2px #164C83.
Shape	border-radius: 0px everywhere including buttons, forms, popovers, tables, modals, calendars, toasts.
Effects	No gradients, blur glass, decorative glows, lifted tiles or heavy shadows; avoid shadows unless necessary for overlapping menus.
Status	Use plain text with a small semantic icon only when useful; no coloured pills/chips/tags/highlight backgrounds.
Typography	Arial/Inter system sans; 14px standard UI, 13px compact tables, 16px section headings, 20–24px page heading.
Spacing	4px grid; 32–36px row height; 36–40px input/button height; consistent 16–24px section padding.
Buttons	Primary solid dark blue; secondary white with 1px border; tertiary text; destructive text with explicit confirmation.
Information density	Use full-width responsive tables, inline filters, visible column headings, simple dividers, no dashboard tiles for ordinary counts.
Accessibility	Persistent labels, high contrast, visible focus, accessible error summary, touch target >= 24px minimum with adequate spacing; target 44px where possible.

7.2 Global shell and information architecture



Use a 224px collapsible left sidebar on desktop; narrow screens get a full-height drawer and persistent page title/actions. Header remains spare. Breadcrumbs are used only where hierarchy is deeper than one level. A navigation item is hidden when the user lacks read permission. Denial responses remain explicit and secure.

7.3 Screen inventory and routes

Route / screen	Primary visible elements	Authorised actions
/dashboard	Pending tasks, recent work table, activity, notices	Open assigned item
/documents	Search, scope, status tabs, table and bulk actions	Create/upload, review, export
/documents/:id	Preview, metadata, versions, participants, timeline	Edit draft, prepare, send, archive
/prepare/:id	Document canvas, field panel, assignees, routing	Place fields, set sequence, preview
/sign/:token	Full document, required-field list, consent	Complete or decline only own task
/stamps	Asset gallery as table, custody and status	Create/request/edit per role
/stamps/:id	Asset preview, revisions, policy, custody log	Approve, retire, delegate
/contracts	Contract register, obligation filters	Draft, review, renew
/templates	Versioned reusable templates	Create/edit/publish
/verify/:reference	Public status, minimal issuer detail, verification form	Verify hash/document
/people	Members, teams, clients, invitations	Manage by grant
/reports	Activity, stamp usage, execution, billing reports	View/export by role
/settings	Profile, security, workspace, integrations	Update scoped settings
/admin	Users, policy, billing, keys, health	Platform/tenant admin only

7.4 Detailed component and interaction rules

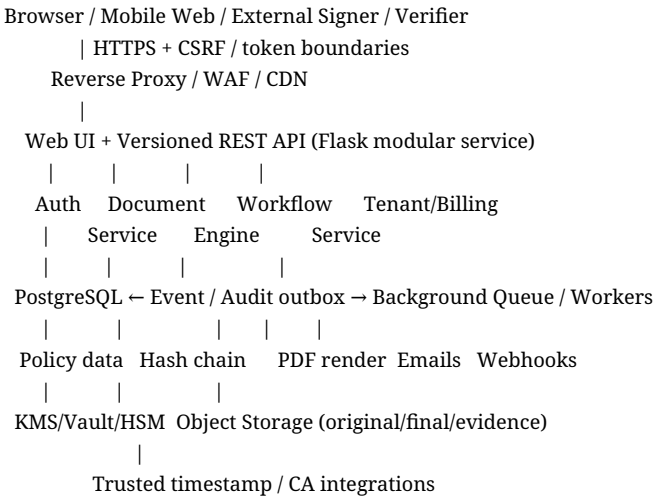
- Document table: show descriptive names, owner, stage, updated date and actions; filters remain a simple inline horizontal control row; no giant summary cards.
- Document preview: central page canvas with thumbnail navigation; right context panel contains fields or evidence, not both simultaneously; preserve document aspect ratio.
- Stamp designer: WYSIWYG on actual-sized white canvas with grid ruler option; property rows for border, type, date and ink; explicit lock/protect controls.
- Signer view: reduce navigation to document, requirements, consent and complete; show the sender identity and document fingerprint/details in expanded trust information.

- Audit timeline: chronological plain rows with timestamp, actor, action, outcome and correlation reference; expandable detail without colour blocks.
- Confirmations: use modal only for irreversible actions; otherwise inline validation and unobtrusive notices; no surprise wizard for a simple operation.
- Error handling: human-readable message, next step, trace/reference ID for support; do not leak internal stack traces.
- Empty states: short explanatory prose plus one meaningful action; no oversized illustration or AI-styled marketing block.

7.5 CSS reference contract

```
:root { --ts-primary:#164C83; --ts-text:#17212B; --ts-muted:#5D6570;
 --ts-border:#D6DADE; --ts-surface:#FFFFFF; --ts-page:#F5F6F7;
 --ts-radius:0px; --ts-shadow:none; --ts-spacing:4px; }
*,*::before,*::after { box-sizing:border-box; border-radius:0 !important; }
body { margin:0; font:14px/1.45 Arial, sans-serif; color:var(--ts-text); background:var(--ts-page); }
button,input,select,textarea { min-height:36px; border:1px solid var(--ts-border); background:#fff; }
button.primary { background:var(--ts-primary); color:#fff; border-color:var(--ts-primary); }
:focus-visible { outline:2px solid var(--ts-primary); outline-offset:2px; }
.status { padding:0; border:0; background:none; font-weight:600; }
/* No gradients, decorative chip badges, glass effects or rounded controls. */
```

8. Logical system architecture



Recommendation: retain the source Flask/Python, PostgreSQL, PyMuPDF/Pillow, server-rendered Jinja2 with modest progressive JavaScript, and Docker deployment for MVP. Use a modular monolith with strict service boundaries and an asynchronous worker pool; defer microservices until proven scaling/organizational need. Each module owns domain rules and APIs, with transaction outbox bridging data changes to queues reliably.

8.1 Core subsystems

Subsystem	Responsibilities / boundaries
Identity & policy	Authentication, sessions, SSO, MFA, memberships,

Subsystem	Responsibilities / boundaries
	effective authorisation and invitations
Documents & rendering	Upload scanning, type detection, conversion, versioned objects, safe preview, hash manifest
Composer	Templates, variables, fields, coordinates, drafts and preview
Envelope engine	Recipients, routing, expiry, signing consent, finalisation and immutable status
Stamp governance	Stamp designs, asset revisions, custodianship, approval and impression records
Trust service	Digests, certificate/PAdES adapters, timestamps, evidence packages and QR verification
Contracts	Contracts, obligations, lifecycle, reminders and amendment lineage
Commercial	Plans, metering, payments, subscription state and billing ledger
Notifications & integrations	Outbox, email/SMS, webhooks, retry/backoff and delivery tracking
Audit / compliance	Append-only events, controlled exports, retention and hold enforcement

8.2 Storage and cryptographic trust model

Persist immutable original, execution-input and issued-final objects in encrypted object storage. Save SHA-256 digests and object manifests in PostgreSQL; enforce immutable object versions/retention where supported. Protect signing/private keys in managed KMS/HSM, never in ordinary application tables. Hash-chained audit segments or write-once log delivery should make manipulation detectable. Preserve timestamp receipts, certificate chain and revocation data for supported long-term verification. When PDF signatures are enabled, use standards-conformant byte-range signatures and assess PAdES profiles with a qualified implementation partner. QR images must encode opaque random references or signed attestations, never personal details or credentials.

8.3 Deployment environments and release operations

- Isolated dev, test, staging and production; staging uses synthetic or masked data.
- Containers behind HTTPS proxy; non-root services; resource-limited isolated converters; managed PostgreSQL and object storage.
- Secrets via vault, environment injection and workload identity; backup/restore and key recovery rehearsed.
- CI gates for formatting, unit tests, security scanning, migrations, browser E2E and infrastructure policy; controlled production release/rollback.
- Metrics: request latency, conversion duration, signing failures, queue lag, webhook dead letters, verification mismatch, stamp approvals and storage usage.

9. Data architecture and principal entities

Entity	Essential fields / links
tenant	id, name, plan_id, policy_revision, residency, created_at
user / identity	id, verified contact, MFA state, external identity references
membership / role_grant	tenant_id, actor_id, role, scope, valid_from/to, authoriser
document / version	tenant_id, owner_id, classification, version_no, original_object_key, sha256, state
template / template_revision	tenant_id, owner_id, variables_schema, controlled_clauses, publication status
envelope	tenant_id, document_version_id, routing_policy, state, expires_at, immutable digest
participant / field	envelope_id, identity, role, sequence, field_type, page, bbox, required
signature_event	participant_id, consent_version, assurance, appearance, signing digest, event_id
stamp_asset / stamp_revision	tenant_id, custodian, approved design, effective/expiry, usage restrictions
stamp_request / impression	requested_by, approved_by, document_version, stamp_revision, bbox, UTC time
certificate / timestamp_receipt	public cert refs, chain, revocation snapshot, signed digest, TSA receipt
verification_record	opaque ref, issued object digest, status, public disclosure policy, supersession
audit_event	tenant, actor, action, object, outcome, correlation, event hash, prev hash
contract / obligation	party set, contract document, status, renewal/termination, assignee, deadline
subscription / usage / invoice	plan, entitlements, period, metered events, ledger entries, payment reference
notification / webhook_delivery	channel, recipient, event, attempt count, next retry, delivery state
retention_hold	object scope, hold reason, authorised approver, release details

Use UUID/ULID-style opaque public IDs and separate human-readable reference numbers. Every tenant-scoped table carries tenant_id and is filtered in repository code, policy checks and optional PostgreSQL row-level security as defence in depth. Index tenant/status/updated, envelope/recipient, verification-reference and documents full-text fields. Use optimistic revision locks on drafts. Store UTC timestamps and render organisation/user timezones.

10. API and integration contract

Method / endpoint (illustrative)	Purpose	Core controls
POST /api/v1/documents	Upload/create document	Membership, malware scan, idempotency key
GET /api/v1/documents/{id}	Metadata and permitted versions	Tenant/object access
POST /api/v1/envelopes	Prepare and dispatch	Immutable version and field validation
POST /api/v1/envelopes/{id}/complete	Execute participant task	Recipient auth, consent, idempotency
POST /api/v1/stamps	Create governed asset	Custodian role
POST /api/v1/stamp-requests/{id}/approve	Authorise impression	Separation of duties, step-up
POST /api/v1/verification/check	Check uploaded digest/reference	Rate limits, safe disclosure
GET /v/{opaque-reference}	Public trust result	Minimal data, enumeration protection
GET /api/v1/audit	Scoped audit search/export	Audit role, export reason
POST /api/v1/webhooks	Register endpoint	Scoped token, signing secret
GET /api/v1/subscriptions/current	Plan, billing and limits	Billing scopes

All mutations should support an idempotency key where retry could duplicate a trust action. Use RFC 7807-style consistent errors, cursor pagination, request and correlation IDs, UTC ISO 8601 times, schema versioning, explicit deprecation, HTTP caching only for public safe assets, and asynchronous job IDs for conversion/signing operations. Webhook headers contain event ID, timestamp and HMAC/algorithm signature; verify freshness and replay cache. API documentation must define permissions and error states for every endpoint.

11. Security, legal and compliance engineering

11.1 Threat model

Threat	Required mitigation
Forged stamp or stolen logo	Custodian policy, asset provenance, protected previews, attributable impression + public verification
Impersonated signer	Recipient binding, identity challenge, explicit consent, MFA for elevated workflows
Altered PDF after issue	Immutable document version, content hash, certificate signature where applicable
Cross-organisation disclosure	Tenant-scoped authorization, signed download links, automated IDOR tests
QR enumeration / phishing	Opaque references, minimal response, verified domains, rate limits, anti-phishing copy
Malicious Office/PDF upload	Content scanning, sandbox conversion, disable

Threat	Required mitigation
	macros/scripts and egress
Compromised admin/API key	Least privilege, step-up, rotation, detection, just-in-time access
Evidence tampering or deletion	Append-only events, chain/hash checkpoints, backups, legal hold
Insider misuse of official seal	Dual approval, delegated authority expiry, alerts and audit exports
Webhook replay / duplicate payment	HMAC validation, idempotency, nonce/time window and ledger reconciliation

11.2 Regulatory interpretation and legal sign-off

The source asks for Uganda data protection compliance and GDPR-ready handling. Implementation must assess the Uganda Data Protection and Privacy Act and applicable regulations, the Electronic Transactions Act and Electronic Signatures Act, relevant evidence/records rules, and requirements for cross-border processing and high-assurance trust services. Where serving other countries, complete a jurisdiction-specific matrix before claiming enforceability. Counsel must approve signature consent wording, identity assurance choices, regulator obligations, stamp/seal terminology, evidence retention and any certificate-provider relationship. These are legal review tasks, not legal conclusions.

11.3 Privacy and accountability

- Data minimisation: public verifier exposes issuer/status/date and only approved additional details; no unrestricted names, document contents or personal identifiers.
- Purpose limitation: analytics and fraud detection use minimal event metadata; optional AI requires clear contractual and consent controls.
- Subject rights: request intake, identity verification, export, correction, deletion decision and legal retention exception trail.
- Data processor agreements and subprocessor register for hosting, SMS, email, analytics and trust services.
- Incident response: classification, containment, evidence preservation, customer notification decision and recovery drill.

12. Testing, validation and acceptance

12.1 Required test layers

- Unit: permission predicates, state transitions, token lifetime, dates/timezones, file coordinate transforms and cryptographic digest helpers.
- Integration: PostgreSQL transaction/outbox, object storage, queue processing, notifications, KMS/TSA, billing adapters and third-party retries.
- End-to-end: create → prepare → approve → sign → stamp → verify → archive; each actor and exception scenario.
- Security: tenant isolation, document attacks, OWASP ASVS-aligned controls, auth bypass, cross-site scripting, CSRF, SSRF, IDOR, QR enumeration and signature-forgery abuse cases.

- Accessibility: WCAG 2.2 AA automated plus manual keyboard/screen-reader, high zoom and narrow display.
- Reliability: crash during PDF render/finalisation, duplicate callbacks, expired tokens, lost email/SMS, DB failover and restore.
- Legal evidence: independent validation of archived PDF, hash, consent, audit timeline, timestamp and certificate material.

12.2 Critical acceptance scenarios

Scenario	Expected result
Unauthorized staff attempts company seal	403 / clear denial; no impression; security audit entry
Stamp approver also requests under four-eyes policy	Self-approval rejected; alternate custodian required
Signer changes issued document bytes	Hash mismatch / invalid execution; original remains preserved
QR on altered PDF	Verification result distinguishes unknown reference from digest mismatch
Recipient forwards signing link	Policy challenge rejects recipient mismatch or requires strong reauthentication
Envelope completion retried 10 times	Exactly one finalisation and immutable completion event
Organisation A guesses organisation B document ID	No content/metadata leakage, including error differences
Certificate revoked after historic signing	Historic proof and present trust status both visible with timestamps
Billing downgraded after issuance	Completed records retained; new paid operations gated
Mobile 320px, keyboard and screen reader	Core read/consent/sign process completes accessibly

12.3 Release gates and traceability

Every FR and NFR must map to at least one design component, test ID, owner and release. P0 requirements are mandatory for launch; any exception needs written risk acceptance, expiry and compensating controls. Release readiness requires security and privacy review, documented independent verification, restore drill, accessibility sign-off, contract tests, data migration rehearsal and stakeholder acceptance. A living RTM should track Proposed → Approved → Implemented → Tested → Accepted statuses.

13. Delivery roadmap and dependencies

Phase	Key outcomes	Exit criteria
0. Discovery and control design	Legal assurance matrix, UX prototypes, threat model, domain/data model, MVP definition	Product/legal/security sign-off
1. Secure document foundation	Tenancy, roles, auth/MFA, upload/scan/preview, storage, audit, flat shell	P0 isolation and document tests pass

Phase	Key outcomes	Exit criteria
2. Stamp and e-sign execution	Stamp builder/custody, envelopes, consent, invited signing, final PDF, verification	Full evidence chain and abuse tests pass
3. Templates and contract workflows	Editor, routing, approvals, contracts, obligations and notifications	Business UAT passes with real workflow simulations
4. Commercial and enterprise readiness	Subscriptions, plans, usage ledger, SSO, APIs, reports, operator tools	Billing reconciliation, DR and SLO pilot pass
5. Assurance and regional scale	Certificate/PAdES options, trust service partners, localisation, resident deployments	Jurisdiction approvals and independent verification pass

Avoid treating historical launch dates in the April 2025 business plan as the current roadmap. Estimate engineering durations after a scoped discovery, system inventory and implementation baseline. Suggested MVP requires P0 features plus indispensable P1 signing and audit/evidence work; do not launch official-seal claims without corresponding control and legal review.

14. Open decisions and assumptions register

ID	Decision needed	Impact / suggested default
D-01	Current legal product owner, brand and trademark rights	Source says EveryByte Systems; confirm before public branding
D-02	Initial geographic scope and acceptable signature tiers	Start Uganda; counsel signs off claims per tier
D-03	Will platform offer certificate-backed signing itself or via partner?	Partner-based trust integration preferred initially
D-04	Payment provider(s), currency and tax invoicing	Use hosted/tokenised integration with UGX/USD support as required
D-05	Default retention and legal hold periods	Contractual policy by record class; avoid one global period
D-06	Enterprise hosting and data residency	Cloud multi-tenant first; isolated deployment where required
D-07	Whether an organisation seal needs dual approval always	Mandatory for high-assurance/official seals; configurable otherwise
D-08	Limits for Free/Pro/Business/Enterprise	Source prices historical, confirm packaging and fair-use limits
D-09	Mobile offline capability	Offline draft only; no unverified offline authoritative execution
D-10	AI suggestions in scope	Later optional module with privacy/tenant opt-in
D-11	Authoritative timestamping and certificate providers	Procure vetted provider; test revocation and validation

ID	Decision needed	Impact / suggested default
D-12	Audit/event immutability implementation	Append-only durable sink with integrity checkpoints

15. Requirements summary and document provenance

This baseline contains 182 individually testable requirements across 19 functional and non-functional domains. IDs are unique by domain and priority-tagged. Technical targets and implementation recommendations are proposals for approval.

Primary input 1: TrustSeal – Business Plan, version 1.0, April 2025, EveryByte Systems (uploaded by requester). Primary input 2: TrustSeal UX Design Document (uploaded by requester, unversioned). All detailed trust governance, cryptographic, privacy, reliability and flat UI requirements not present in those inputs are newly proposed in this v2.0 specification.

Recommended normative reference areas for later compliance annex: Uganda privacy/electronic-transaction statutes; OWASP ASVS; WCAG 2.2; ISO/IEC 27001 and 27701; ETSI electronic-signature/PAdES specifications; ISO 32000-2 (PDF); applicable PCI DSS boundaries for selected payment architecture. Validate versions, applicability and legal interpretations before formal adoption.